

DDoS Analysis - Report

I. Executive Summary

This report analyzes five sophisticated Distributed Denial of Service (DDoS) botnets—XorDDoS, LunoBotnet, Vo1d Botnet, Eleven11bot, and Ballista IoT Botnet—active between late 2023 and early 2025. These campaigns target a wide range of systems, from Linux servers to Android TV devices and IoT routers.

Key findings show a highly professional, financially motivated threat landscape dominated by DDoS-as-a-Service models, often supplemented by cryptojacking (LunoBotnet) or building massive proxy networks (Vo1d Botnet). Attacks use advanced, evasive techniques, including application-layer floods and custom encryption. The scale, particularly of the 1.6-million-device Vo1d Botnet, introduces a severe potential for widespread service disruption and unprecedented societal risks like media manipulation. Effective defense requires immediate firmware patching, strong access control (MFA), and behavioral threat detection.

II. Introduction

Distributed Denial of Service (DDoS) attacks continue to evolve, posing a significant threat to global services. This report provides an analysis of five major botnet campaigns identified between 2023 and 2025.

The analysis focuses on the specific targets, the technologies and methods used for infection and attack, the primary attacker motives, and recommended defensive strategies. The botnets highlight a shift toward sophisticated, multi-layer attacks that compromise diverse devices, from high-capacity servers to consumer IoT, for financial gain through DDoS-for-hire and secondary revenue streams. Understanding these specific threats is crucial for effective security planning and mitigation.

III. XorDDoS

Target

The XorDDoS trojan primarily targets Linux machines, converting them into "zombie bots" to carry out attacks. The trojan has also expanded its reach to Docker servers.

From November 2023 to February 2025, over 70 percent of attempted attacks using XorDDoS targeted the United States. Nearly 50% of the successfully compromised victims during this period were also located in the United States, followed by Japan, Canada, Germany, and others.

Technology Used

- Infection Method: The malware relies on Secure Shell (SSH) brute-force attacks to gain remote access to target Linux devices. Once valid SSH credentials are obtained, a script is executed with root privileges to download and install XorDDoS.
- Persistence: The malware implements persistence mechanisms by installing an init script and a cron job script to ensure it launches automatically at system startup and evades detection.
- Decryption: The latest "VIP version" of the XorDDoS malware continues to use the same decryption function and the XOR key "BB2FA36AAA9541F0" to decrypt its embedded configuration, including C2 server URLs or IPs.
- Control Infrastructure: The trojan utilizes a multi-layer control network, including:
 - XorDDoS Trojan: The malware installed on victim machines.
 - Sub-controllers: These control the XorDDoS trojans. A new "VIP" version of the sub-controller was discovered in 2024.
 - Central Controller ("BUC distribute control"): A new version of the controller that enables threat actors to manage multiple XorDDoS controllers simultaneously, enhancing the coordination of more sophisticated and widespread attacks.

Attacker's Motive

The document strongly suggests that the XorDDoS tools and infrastructure are a product suite developed for sale on the underground market. This implies a financial motive for the developers. The language settings and user interface of the control tools strongly suggest the operators are Chinese-speaking individuals.

Overall Impact

The XorDDoS trojan significantly increased in prevalence from 2020 to 2023. Its impact is global, with compromised systems attempting to target several countries. The continued development of a "VIP version" and a central controller indicates the threat actors' continued investment and ability to launch more sophisticated and widespread attacks. The malware successfully turns infected Linux machines and Docker servers into DDoS botnet members.

Defensive Strategies

- Endpoint Security: Cisco Secure Endpoint is ideally suited to prevent the execution of the malware.
- Network Security: Cisco Secure Firewall can detect malicious activity associated with the threat. The security services edge (SSE) solution, Cisco Secure Access, is also good.
- Access Control: Cisco Duo provides multi-factor authentication to ensure only authorized users access the network, which could mitigate the success of the initial SSH brute-force attacks.
- Gateway/DNS Security: Cisco Umbrella (secure internet gateway) blocks users from connecting to malicious domains, IPs, and URLs associated with the command-and-control (C2) infrastructure.
- Threat Detection: Open-source Snort Subscriber Rule Set customers can use Snort SIDs 64669, 64668, and 64667 for this threat. ClamAV detections are also available.

Resources

- <https://vx-underground.org/Malware%20Analysis/2025/2025-04-17%20-%20Unmasking%20the%20new%20XorDDoS%20controller%20and%20infrastructure>
- <https://blog.talosintelligence.com/unmasking-the-new-xorddos-controller-and-infrastructure/>

IV. LunoBotnet

Target

The LunoBotnet is designed to target Linux environments, particularly internet-facing servers and game-hosting platforms. Specific attack modules are explicitly tailored to target online gaming services.

- **Gaming Platforms:** The botnet features target routines for popular gaming servers, including Roblox, Minecraft, and Valve (e.g., CS:GO, Team Fortress 2).
- **Resource-Constrained Systems:** The malware targets embedded Linux distributions (like BusyBox, OpenWrt, Alpine Linux) by replacing the legitimate ash shell with the xmrig cryptominer, indicating a target on systems with limited resources for cryptocurrency mining.

Technology Used

LunoBotnet employs a multi-faceted approach, combining DDoS attack modules with robust persistence and anti-analysis mechanisms.

DDoS Attack Methods

The botnet features a C2 command handler supporting dozens of DDoS attacks. These attacks cover multiple network layers and protocols, including:

- **Layer 4 (Transport/Network Layer) Floods:**
 - **Standard Volumetric Floods:** udp-flood, tcp-flood, syn-flood, ack-flood, icmp-flood.
 - **Advanced Floods:** udp-bypass and tcp-bypass use randomized packet sizes and dynamic destination ports to evade basic signature-based detection.
 - **Gaming-Specific Attacks:** Raknet-based floods (raknet, raknet-mix) to bypass simple firewall rules by completing the RakNet protocol handshake; game-roblox (UDP-flood); mc-fakejoin and minecraft-fakeplay (fake logins/traffic); valorant-quic (targets QUIC-based servers).
- **Layer 7 (Application Layer) Floods:**
 - **Browser Simulation:** browser and other HTTP/TLS floods that simulate real browser traffic using a hardcoded list of random user-agents (4 agents) and 102 legitimate referrers (e.g., Google, Facebook, Wikipedia) to mimic human browsing and evade detection.

Stealth and Resilience

- Self-Healing: Uses watchdog-based respawning via an infinite loop, continuously monitoring and respawning its process under a disguised name if terminated.
- Persistence: Achieved by replacing legitimate system binaries like `/usr/bin/ss`, `/usr/bin/fuser`, `/usr/bin/tcpdump`, and `/usr/bin/netstat` with its own binary.
- Masquerading: Ignores termination signals (e.g., `SIGTERM`, `SIGINT`) and disguises its process name as `"bash"` or `"[kworker/0:1]"` to blend in with legitimate processes.
- Anti-Analysis: Performs checks for debugging tools (e.g., `gdb`, `strace`, `ida`), debugger presence (`TracerPid`), and timing to detect execution delays, self-deleting if an anomaly is found.
- Cryptojacking: Downloads and executes the `xmrig` Monero miner, saving it as `/bin/ash` to maximize CPU usage for mining.

Attacker's Motive

The Luno Botnet campaign has a dual motivation:

1. Cryptomining: The theft of computational resources to mine cryptocurrency (Monero) for financial gain.
2. DDoS-as-a-Service (DDoS-for-hire): The provision of distributed denial-of-service attacks for monetization. The architecture and pricing model, which offers tiered plans from "Basic" (\$9) to "VIP" (\$120), suggest an intent for long-term monetization and operational flexibility. The attacker sells these services via a Telegram channel.

Technology Used

The LunoBotnet poses both operational and financial risks for organizations.

- Service Disruption: The primary impact is the loss of service due to the modular and advanced DDoS attacks, affecting targeted websites, services, and especially online gaming platforms.
- Resource Theft: Cryptojacking activities lead to the theft of CPU resources, causing performance degradation and unexpected CPU spikes on infected Linux servers, especially targeting resource-constrained systems.
- System Compromise and Resilience: The malware's ability to replace core system binaries and maintain persistence through self-healing loops makes it a long-term threat that is difficult to detect and remove.

Defensive Strategies

- Execution/Cryptojacking: Monitor for unexpected CPU spikes and unauthorized xmrig processes.
- Persistence: Deploy file integrity monitoring (FIM) for sensitive directories like /bin and /usr/bin/ to detect binary replacement.
- Persistence/Execution: Check the hash of critical binaries like /bin/ash against a known-good baseline.
- Masquerading: Monitor for process names that don't match their binary path or hash (e.g., the Luno binary running but naming itself "bash").
- Self-Healing: Alert on short-lived bash processes continuously spawning a fork-exec loop.
- Command and Control (C2): Enforce network filtering to block unauthorized connections to known Monero mining pools (e.g., pool.supportxmr[.]com:3333) or C2 domains (botnet[.]world).
- C2 Communication: Alert on manual DNS resolution attempts using known suspicious fallback IPs
- DDoS Impact: Monitor for high network throughput by non-root services or obscure binaries to detect ongoing DDoS threads.
- General: Use EDR rules to flag suspicious prctl process renaming attempts.

Resources

- <https://vx-underground.org/Malware%20Analysis/2025/2025-09-09%20-%20LunoBotnet%20A%20Self-Healing%20Linux%20Botnet%20with%20Modular%20DDoS%20and%20Cryptojacking%20Capabilities>
- <https://cyble.com/blog/lunobotnet-a-self-healing-linux-botnet/>

V. Vo1d Botnet

Target

The Vo1d botnet primarily targets Android TV devices and set-top boxes across 200+ countries and regions. These devices are compromised and turned into "digital puppets".

The top 15 infected countries by percentage (based on data collected from February 1 to 15, 2025) are:

- Brazil: 24.97%
- South Africa: 13.60%
- Indonesia: 10.54%
- Argentina: 5.27%
- Thailand: 3.40%

Technology Used

The botnet is a new variant of the Vo1d botnet, which utilizes a downloader named jddx. Key technologies and techniques include:

- Infection Method: Targets Android TV devices and set-top boxes.
- Encryption & Stealth: Uses RSA encryption to secure network communication, preventing C2 (Command and Control) takeover, and an enhanced payload delivery optimization with XXTEA encryption. The malware employs a modified version of the XXTEA algorithm called asr_xxtea (Arithmetic Right Shift XXTEA) for payload decryption, highlighting the group's technical expertise.
- Evasion/Resilience: Uses a Domain Generation Algorithm (DGA) that evolved from 5 to 32 seeds, capable of generating over 100,000 DGA domains. This is complemented by a Redirector C2 mechanism and a multi-port, multi-domain approach for traffic distribution, enhancing resilience against disruption.

Attacker's Motive

The primary known motive for the Vo1d botnet is financial profit. This is achieved through three core business objectives:

- Proxy Networks: Building anonymous proxy services by leveraging infected devices for commercial sale. This model has been proven lucrative by the proxy service, which illegally generated over \$99 million.
- Ad Fraud and Fake Traffic: Engaging in activities like ad promotion and click fraud.

- **Potential for Large-Scale Cyberattacks:** Although currently focused on profit, the botnet's full control over 1.6 million devices provides the capability to pivot to mass cyberattacks, including DDoS.

Overall Impact

- **Cyberattack Potential:** With 1.6 million infected devices, the botnet's potential for DDoS attacks is massive. Its scale is 100 times larger than the 2024 Cloudflare DDoS attack that used only 15,000 devices. If weaponized, it could disrupt critical systems like banking, healthcare, and aviation, causing widespread chaos.
- **Media & Societal Risk:** Compromised TVs and set-top boxes can be exploited as core media devices to broadcast unauthorized content. This includes spreading violent, terrorist, or pornographic content, or using deepfake technology for political propaganda, which would have a devastating societal impact. This was seen in a real-world case on February 24, 2025, where TVs at the U.S. Department of Housing and Urban Development showed unauthorized AI-generated footage.

Defensive Strategies

Supply Chain and Manufacturer Mitigation

- **Mandatory Audits:** Device manufacturers must undergo strict security audits to prevent the pre-installation of malicious components at the factory level.
- **Secure Default Configuration:** Devices should ship with secure default settings, disabling unnecessary services and restricting the installation of unsigned or third-party firmware.

User Behavior and Device Security

- **Install Protective Software:** Users must recognize that TV boxes are vulnerable devices, similar to smartphones, and should install protective security software where possible.
- **Avoid Unauthorized Software:** Users should strictly avoid downloading cracked apps, third-party software, or flashing unofficial firmware to minimize exposure and malware proliferation.
- **Regular Software Updates:** Keeping the Android TV operating system and all installed applications fully patched and updated can mitigate vulnerabilities exploited by botnets.
- **Network Segmentation:** Network administrators and advanced users should isolate or segment Android TV devices on a dedicated network to prevent a potential breach from compromising critical assets on the main home or corporate network.

- DNS Filtering/Blacklisting: Implement DNS filtering to block resolution of known C2 domains associated with the botnet, such as those listed in the Indicators of Compromise (IOC).

Resources

- <https://vx-underground.org/Malware%20Analysis/2025/2025-02-27%20-%20Long%20Live%20The%20Vo1d%20Botnet%20-%20New%20Variant%20Hits%201.6%20Million%20TV%20Globally>
- https://blog.xlab.qianxin.com/long-live-the-vo1d_botnet/

VI. Eleven11bot

Target

The DDoS attacks launched by Eleven11bot were primarily directed against telecom providers and gaming platforms.

Technology Used

- Initial Discovery and Scale: Initially tracked by Nokia Deepfield's Emergency Response Team (ERT), it was estimated to have compromised over 30,000 devices. Later, GreyNoise refined its understanding, suggesting the actual number of compromised devices was likely fewer than 5,000, with initial estimates inflated by misidentified network protocol traffic.
- Compromised Devices: The botnet primarily comprised compromised devices like security cameras and network video recorders (NVRs).
- Botnet Type: Eleven11bot is likely a Mirai variant that uses a single new exploit targeting HiSilicon-based devices, particularly those running TVT-NVMS9000 software.
- Expansion Methods: The botnet actively expands its operations using malicious activities such as:
 - Brute-force attacks against login systems (e.g., Telnet and SSH).
 - Exploitation of weak and default passwords on IoT devices.
 - Targeting specific security camera brands like VStarcam using hardcoded credentials.
 - Network scanning for exposed Telnet and SSH ports.

Attacker's Motive

While GreyNoise explicitly states they do not speculate on attribution, the report notes that 61% of the observed malicious IP addresses (636 out of 1,042) are traced to Iran. It also mentions that the increase in botnet activity came just two days after the U.S. administration reasserted its "maximum pressure" campaign on Iran, imposing new economic sanctions. This suggests the activity could be politically or geo-strategically motivated, possibly a retaliatory or disruptive action.

Overall Impact

- **Attack Magnitude:** The botnet has been described as "one of the largest known DDoS botnet campaigns observed since the invasion of Ukraine in February 2022".
- **Disruption:** The DDoS attacks were directed at telecom providers and gaming platforms, with some attacks lasting multiple days and causing widespread disruptions.
- **Source Integrity:** The vast majority of the observed IP addresses (96%) were identified as non-spoofable, meaning they originated from genuine, accessible, and compromised devices, making them reliable sources of malicious traffic.

Defensive Strategies

- **Secure IoT Devices:** Immediately change default passwords on all IoT devices, update firmware to patch known vulnerabilities (like those in HiSilicon-based devices), and disable remote access (Telnet/SSH) where unnecessary.
- **Block Known Malicious IPs:** Proactively block traffic originating from the known malicious IP addresses associated with the botnet, using real-time threat intelligence data.
- **Monitor Network Logs:** Actively monitor network logs for signs of compromise, specifically looking for unusual login attempts on Telnet and SSH ports, as attackers use brute-forcing techniques.
- **DDoS Protection:** Implement and enable dedicated DDoS protection and rate-limiting services to harden network defenses against the high-intensity, volumetric attacks this botnet is designed for.

Resources

- <https://vx-underground.org/Malware%20Analysis/2025/2025-02-28%20-%20New%20DDoS%20Botnet%20Discovered%20-%20Over%2030,000%20Hacked%20Devices,%20Majority%20of%20Observed%20Activity%20Traced%20to%20Iran>
- <https://www.greynoise.io/blog/new-ddos-botnet-discovered>

VII. Ballista IoT Botnet

Target

The primary targets of the Ballista botnet are TP-Link Archer routers, specifically exploiting a remote code execution (RCE) vulnerability, CVE-2023-1389. The AX21 (aka AX1800) model is explicitly mentioned as a target.

Organizations that have been targeted by the botnet include those in the manufacturing, medical/healthcare, services, and technology sectors across the U.S., Australia, China, and Mexico. At the time of writing the report, over 6,000 vulnerable devices were identified as connected to the internet.

Technology Used

- **Initial Access & Exploitation:** It exploits the RCE vulnerability CVE-2023-1389 in the router's web management interface, which stems from a lack of user input sanitization in the country form of the `/cgi-bin/luci;stok=/locale` endpoint.
- **Malware Dropper:** A cleartext shell dropper named `dropbpb.sh` is injected and executed with root privileges to download and execute the malware binaries (T1105). A new variant of the dropper uses Tor domains for stealth.
- **Malware Binaries:** Five pre-compiled binaries (`bpb.$arch`) are dropped onto the system for different architectures (`mips`, `mipsel`, `armv5l`, `armv7l`, `x86_64`).
- **Command and Control (C2):** The malware establishes a TLS encrypted C2 channel on port 82 (T1573, T1095) with the attacker's server (2.237.57.70).
- **DDoS Capability:** The malware includes a Flooder Module (T1499) with a command-and-control keyword, `flooder`, that can be used to execute DoS attacks. The identified implementation uses a RAW socket for a tcpgeneric flood attack.

Attacker's Motive

The primary known motive for the Ballista IoT botnet is financial profit.

- **Distributed Denial of Service (DDoS) Attacks:** The botnet is weaponized to launch large-scale flood attacks, which are often sold as a service to other criminals (DDoS-for-hire).
- **Backdoor Access/Espionage:** The ability to run remote shell commands suggests a motive to maintain control for potential data theft, lateral movement within targeted networks (manufacturing, healthcare, etc.), or selling network access.

Overall Impact

- **Compromised Devices:** The botnet compromised thousands of TP-Link Archer routers globally, with over 6,000 vulnerable devices identified online.
- **DoS/DDoS Attacks:** Compromised routers can be used to launch large-scale Denial of Service attacks against other targets.
- **Data Exposure and Security Risk:** The malware attempts to read numerous sensitive files on the local system, including configuration and user/authentication-related files (e.g., /etc/passwd, /etc/shadow), which could be used for exfiltration, creating backdoors, or lateral movement.

Defensive Strategies

- **Patching/Firmware Updates:** The most effective defense against the initial access vector (CVE-2023-1389) is for users to deploy new, patched firmware to their routers.
- **Network Segmentation & IoT Security:** Utilizing IoT/OT Security to provide device identification allows administrators to implement tailored security policies for vulnerable devices, enhancing the network's security posture.
- **Intrusion Prevention Systems (IPS):** Deploying an IPS (e.g., Cato IPS) with both tailored and generic protections for blocking CVE-2023-1389.
- **Behavioral Detections:** Using security tools that provide behavioral detections for malware activity, such as lateral movement and C2 communication, can block the post-exploitation phases of the attack.
- **Default Credential Change:** While not the primary vector, changing default/weak credentials on web interfaces, a common IoT botnet target, would improve security.

Resources

- <https://vx-underground.org/Malware%20Analysis/2025/2025-03-11%20-%20Cato%20CTRL%20Threat%20Research%20-%20Ballista%20%E2%80%93%20New%20IoT%20Botnet%20Targeting%20Thousands%20of%20TP-Link%20Archer%20Routers>
- <https://www.catonetworks.com/blog/cato-ctrl-ballista-new-iot-botnet-targeting-thousands-of-tp-link-archer-routers/>

VIII. Conclusion

The analysis of the five botnets confirms the DDoS threat is highly professionalized and financially motivated. Threats range from Linux-targeting malware like XorDDoS and LunoBotnet (using cryptojacking) to large-scale compromises of consumer devices like Android TVs (Vo1d Botnet) and routers (Ballista IoT Botnet).

Crucially, the sheer scale of the Vo1d Botnet (1.6 million devices) shows a severe potential for societal risk beyond typical service disruption. Defense requires a multi-layered approach: prioritizing firmware patching and MFA against initial compromise, and deploying advanced security tools capable of behavioral detection to counter evasive persistence techniques. Proactive defense and rapid response are essential for operational resilience.

IX. Contact Information

For any further information or clarification regarding these findings, please contact:

Name: Nandakumar K.S

Email: nandu682015@gmail.com

Mulearn: nandakumark.s@mulearn

Date of Report: 19th October 2025